

Capítulo 8

Enumeração de informações e serviços

8.1. Objetivos

- Mapear a rede
- Descobrir serviços e versões sendo executadas na rede

8.2. Enumeração

As técnicas de enumeração são utilizadas como um complemento às fases de fingerprint e varredura.

O objetivo é descobrir serviços e versões que estão sendo executados no sistema alvo, facilitando a posterior pesquisa de vulnerabilidades e exploits específicos.

Quanto mais informações tivermos sobre nosso alvo, mais fácil será para encontrarmos vulnerabilidades e melhorarmos nossos vetores de ataque. Sabendo os serviços rodando e as versões dos mesmos, torna-se possível encontrarmos os exploits corretos e as vulnerabilidades que poderão ser exploradas.

Além disso, na fase de enumeração, mapeamos toda a rede do alvo, descobrindo os pontos falhos e onde podemos explorar para conseguir acesso a informações estratégicas.

8.3. Aquisição de banners

Falaremos agora a respeito da captura de informações sobre os serviços que estão rodando em uma máquina-alvo por meio da leitura de seus respectivos banners que são aquelas mensagens que contém informações como o tipo do serviço, sua versão, etc. Essas informações visam estabelecer um levantamento dos serviços utilizados, onde o foco de um possível ataque pode estar voltado para a exploração de vulnerabilidades desses serviços.

8.3.1. Técnicas clássicas

Sem utilizar ferramentas específicas, é possível conseguir informações dos serviços que estão sendo executados em determinada porta. Abaixo veremos dois exemplos, utilizando ftp e telnet.

Obtendo banner de um servidor ftp:



```
#ftp 192.168.200.254
```

Obtendo banner de um servidor de e-mail:



```
#telnet 192.168.200.205 25
HELO [domínio]
MAIL FROM: [endereço_origem]
RCPT TO: [endereço_destino]
DATA
( ... msg ... )
.
quit
```

Com o comando telnet, podemos tentar conectar em todas as portas existentes para verificar o que está sendo executado.

Obviamente que esse é um método lento e impossível de ser executado nas mais de 65000 portas existentes, mas é interessante conhecê-lo, e ainda evita a detecção por IDS ou firewall.

8.3.2. Ferramentas

- Nmap

Realiza varredura de rede, buscando hosts ativos, portas abertas e serviços sendo executados.

- Xprobe2

Analisa banners de sistemas operacionais, comparando com um banco de dados interno, onde compara-os e informa o S.O. utilizado e a versão do mesmo.

- Amap

Analisa banners de serviços que estão sendo executados, e informa o nome e

versão.

- AutoScan

Faz varredura na rede e informa hosts ativos, portas abertas e serviços sendo executados. Funciona através de uma interface gráfica.

- Maltego

Faz varredura de redes, serviços, protocolos, domínios e várias outras opções, informando de forma gráfica a relação entre os hosts ativos.

- Lanmap

Varre toda a rede e captura pacotes, criando ao longo de sua execução um arquivo .PNG com o mapa da rede, informando graficamente a relação das máquinas encontradas.

- Cheops

Varre toda a rede em busca de hosts ativos, informando graficamente, através de um mapa, os hosts ativos, S.O. sendo executado, portas abertas, serviços sendo executados. Utiliza o nmap por debaixo de sua execução, para realizar as varreduras.

- Nessus

Através de plugins específicos, varre um determinado alvo, informando as vulnerabilidades encontradas, inclusive exibindo o link de onde podemos encontrar mais informações sobre determinada vulnerabilidade e seu exploit.

8.4. Prática dirigida

8.4.1. Capturando banner de aplicações (de forma ativa)

1 - A partir da sintaxe abaixo, utilizando os programas Nmap, Xprobe2 e Amap, faça o reconhecimento dos serviços e sistemas operacionais rodando nas máquinas da rede alvo, e compare os resultados de cada programa.



```
nmap -sV -O [ip_alvo]
Xprobe2 -p TCP:80:open <ip>
Amap <ip> <porta>
```

8.5. Mapeando graficamente a rede

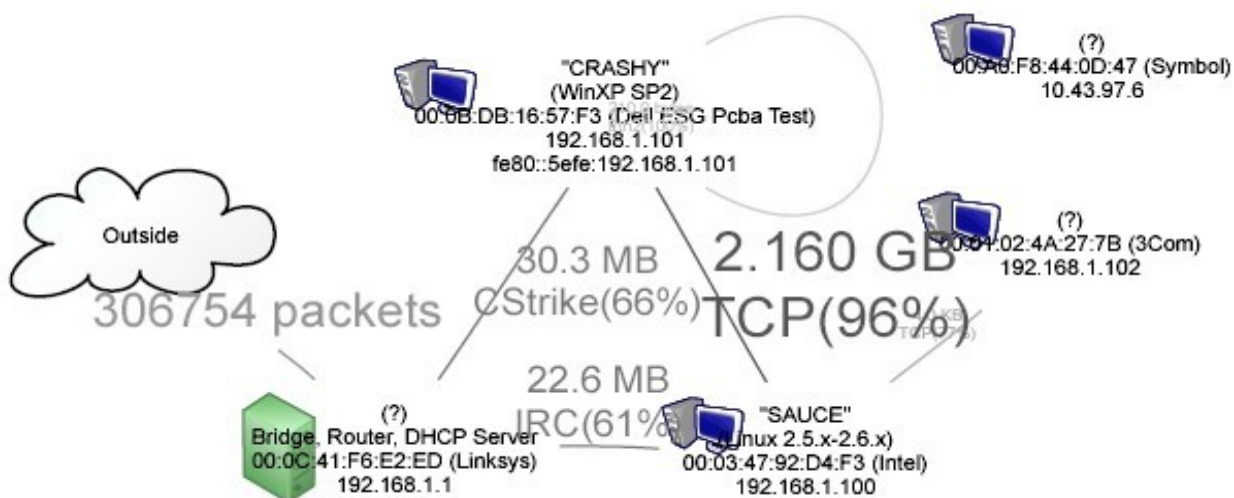
Os programas de linha de comando funcionam muito bem para varrer redes, descobrir hosts ativos, serviços sendo executados e versões dos mesmos. No entanto, quando temos um mapa gráfico à mão, torna-se muito mais fácil visualizarmos a estrutura da rede e definirmos os vetores de ataque de forma mais consistente.

Justamente por isso, abordaremos nos tópicos seguinte exemplos de ferramentas existentes no Backtrack 4 que permitem mapear a rede graficamente.

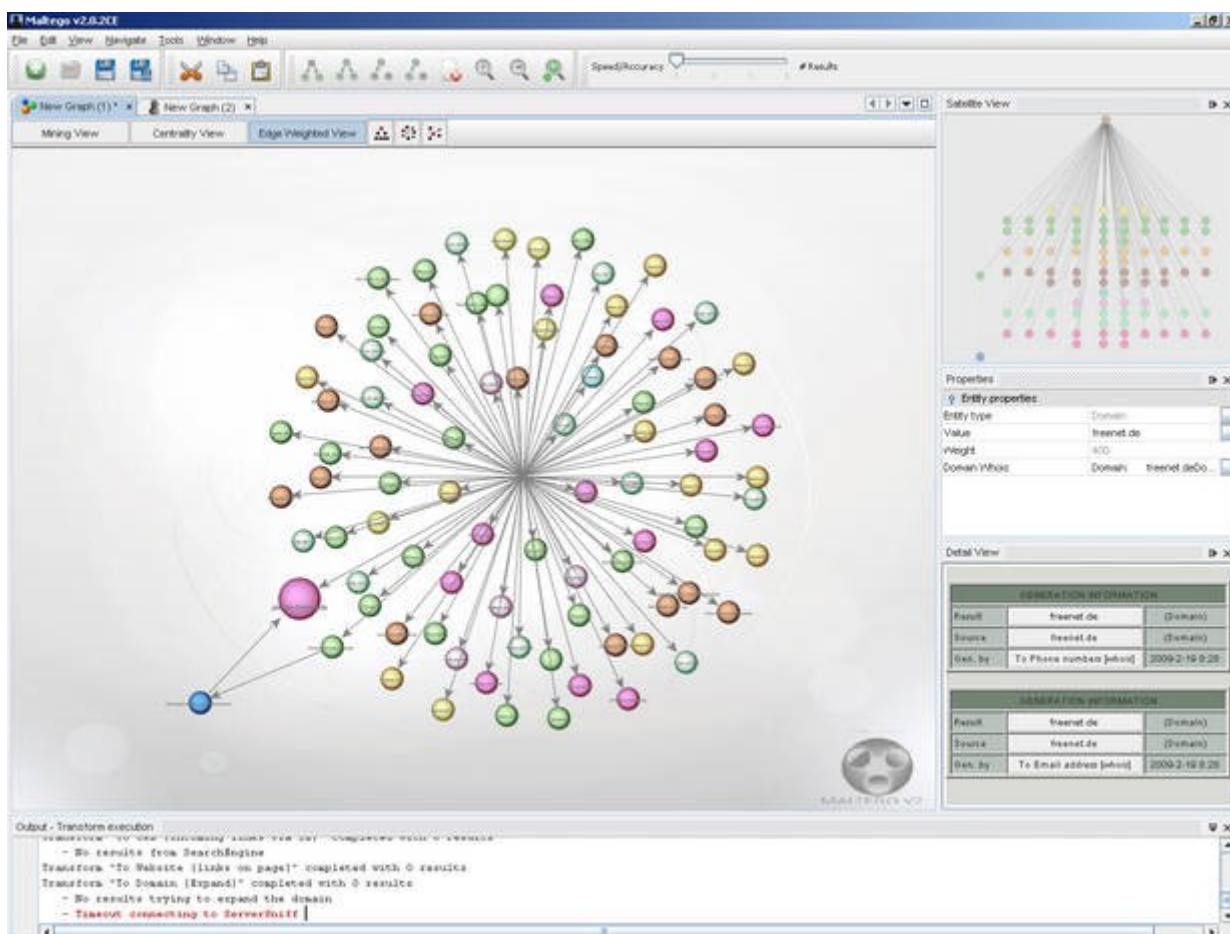
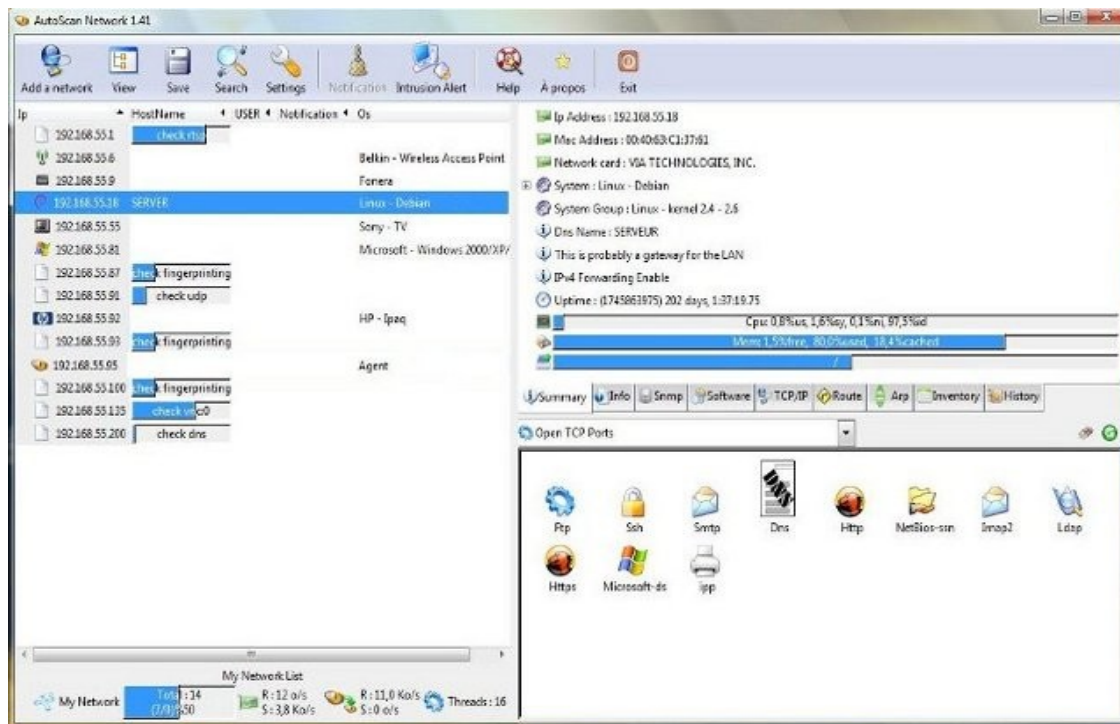
Algumas rodam em linha de comando, como o Lanmap, por exemplo, e outras possuem uma interface gráfica, que facilita a operação, como o Cheops e Maltego.

8.5.1. Lanmap e Cheops

Ex: lanmap -i eth0 -r 30 -T png -o /tmp/



8.5.2. AutoScan



8.6. Descobrindo Vulnerabilidades

8.6.1. Nessus

Nessus é uma das ferramentas mais conhecidas para descoberta de vulnerabilidades em redes e sistemas.

Com um conjunto sempre atualizado de plugins, baseado em sua linguagem de script chamada NASL, ele faz a varredura de todo os IPs definidos em sua configuração, buscando vulnerabilidades e brechas na configuração dos serviços, informando-os em um relatório final, onde define o grau de risco das vulnerabilidades encontradas.

Inicialmente o Nessus era um software opensource, mas a partir da versão 3.0 passou a ser uma ferramenta comercial, disponível gratuitamente apenas para uso doméstico. Portanto, é possível baixar gratuitamente o Nessus em seu site www.nessus.org e registrar-se para conseguir a chave de ativação, para poder utilizar a ferramenta em testes particulares.

Vamos ver no tópico a seguir como baixar e configurar o Nessus para sua utilização em análise de vulnerabilidades.

8.7. Prática dirigida

8.7.1. Instalando o Nessus

1. Acesse o endereço nessus.org/download/
2. Baixe a versão 4.2.2 do Nessus para Ubuntu 8.04

3. Instale o pacote:



```
#dpkg -i Nessus-4.2.2-debian5_i386.deb
```

4. Adicione um usuário que será o administrador do Nessus:



```
#!/opt/nessus/sbin/nessus-adduser
```

8.7.2. Registrando e iniciando

1. Acesse www.nessus.org/register
2. Escolha a versão Professional ou Home (a versão Home é gratuita)
3. Informe um endereço de e-mail (para onde eles enviarão o número de registro)



```
#!/opt/nessus/bin/nessus-fetch --register xxxx-xxxx-xxxx-xxxx  
#!/opt/nessus/sbin/nessus-update-plugins  
#/etc/init.d/nessusd start
```

4. Acesse em seu browser: <https://127.0.0.1:8834/>

8.8. Definindo vetores de ataque

É importante, antes de iniciarmos qualquer ação efetiva contra nosso alvo, definirmos as várias possibilidades de ataques existentes dentro do contexto das informações adquiridas nas fases anteriores.

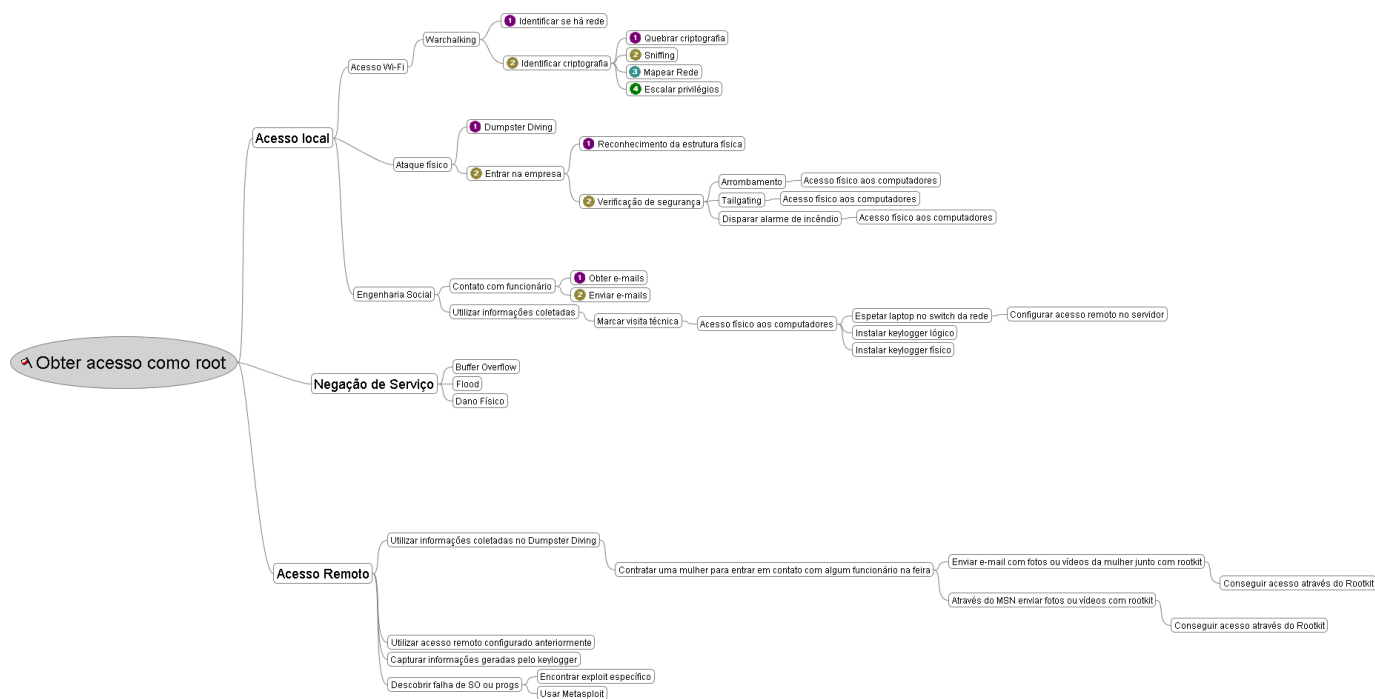
Por exemplo, se definirmos que o objetivo do teste de invasão, é conseguir acesso como root no sistema, após o levantamento das informações, fingerprint, enumeração e etc, decidiremos quais são os possíveis ataques que podem ser realizados de acordo com as informações que conseguimos.

Após definirmos os ataques, vamos classificá-los em nível de dificuldade, sendo “1” praticamente em dificuldade, e “10” o valor que definiremos os ataques de maior dificuldade e com alta improbabilidade de conseguir sucesso.

Para definirmos os vetores, e colocá-los em um mapa gráfico que facilite sua visualização e compreensão, vamos utilizar uma técnica chamada “mapas mentais”, desenvolvida para facilitar a reunião de informações de forma resumida de condensada em um mapa gráfico, e posterior compreensão das mesmas sem perder seu principal significado e conteúdos.

Vamos utilizar um programa específico para isso, e com a reunião das informações conseguidas até o momento, definirmos os vetores de ataque. Devemos atentar que, ao longo do curso, novos vetores serão acrescentados e alterados, de acordo com a evolução de nosso conteúdo.

Vejamos abaixo um exemplo de mapa mental com vetores de ataque definidos:



8.9. Prática dirigida

1. Vamos, em primeiro lugar, instalar o software necessário para a criação de mapas mentais:



```
#aptitude install freemind
```

2. Utilizando as informações reunidas até o momento, vamos definir os vetores de ataque, classificá-los e criar um mapa mental com os mesmos.
3. Acrescente isso ao relatório.

8.10. Contramedidas

- Como a maioria das varreduras e aplicativos de mapeamento utilizam flags de conexão, uma boa configuração de regras do firewall já bloqueia a maiorias das tentativas de varreduras.
- Manter IDS/IPS bem configurados para detectar e bloquear IPs que realizam tentativas de varreduras.
- Realizar constantemente auditorias nas regras de IDS/IPS e firewalls, testando se os mesmos podem ser burlados e como. E a partir disso, criar e/ou adaptar regras.